Lab Writeups

Access control vulnerabilities

PortSwigger Web Security Academy — Lab Solutions

Prepared by
Youssef Reda

Contents

1 Lab: Unprotected Admin Functionality 1

2 Lab: Unprotected Admin Functionality with Unpredictable URL 1

3 Lab: User Role Controlled by Request Parameter 1

4 Lab: User Role Can Be Modified in User Profile 1

5 Lab: Method-Based Access Control Can Be Circumvented 2

6 Lab: User ID Controlled by Request Parameter 2

7 Lab: User ID Controlled by Request Parameter with Unpredictable User IDs 2

8 Lab: User ID Controlled by Request Parameter with Data Leakage in Redirect 2

9 Lab: User ID Controlled by Request Parameter with Password Disclosure 3

10 Lab: Insecure Direct Object References 3

11 Lab: Multi-Step Process with No Access Control on One Step 3

12 Lab: Referer-Based Access Control 3

Lab: Unprotected Admin Functionality

1. Navigate to `/robots.txt` and inspect the `Disallow` directive to discover the admin panel path.
2. Navigate to the disclosed path, `/administrator-panel`.
3. Delete the user `carlos` from the admin panel.

Lab: Unprotected Admin Functionality with Unpredictable URL

1. Inspect the lab's home page source using Burp Suite or browser developer tools.
2. Find the JavaScript code that discloses the admin panel URL.
3. Navigate to the discovered URL and delete the user `carlos`.

Lab: User Role Controlled by Request Parameter

1. Navigate to `/admin` and confirm that access is denied.
2. Log in using the credentials `wiener:peter`.
3. In Burp Proxy, enable interception for HTTP responses and submit the login form.
4. Inspect the response and locate the cookie `Admin=false`.
5. Change the cookie value to `Admin=true` and forward the response.
6. Navigate to `/admin` and delete the user `carlos`.

Lab: User Role Can Be Modified in User Profile

1. Log in using `wiener:peter` and navigate to your account page.
2. Use the feature to update your account email address.
3. Inspect the response and locate your `roleid`.
4. Send the email update request to Burp Repeater and add the following property to the JSON request body:

```
"roleid": 2
```

5. Resend the request and verify that your `roleid` is now `2`.
6. Navigate to `/admin` and delete the user `carlos`.

Lab: Method-Based Access Control Can Be Circumvented

1. Log in using the administrator credentials `administrator:admin`.
2. Open the admin panel, initiate the promotion of `carlos`, and send the resulting request to Burp Repeater.
3. Open a private browser window and log in as `wiener:peter`.
4. Replace the session cookie in Repeater with the non-admin user's session cookie and resend the request. Observe the `Unauthorized` response.
5. Change the HTTP method from `POST` to `POSTX` and resend the request. Observe the different error response.
6. Use Burp Repeater's *Change request method* option to convert the request to `GET`.
7. Change the username parameter to `wiener` and resend the request to promote your account to administrator.

Lab: User ID Controlled by Request Parameter

1. Log in using `wiener:peter` and navigate to your account page.
2. Observe that the URL contains your username in the `id` parameter.
3. Send the account request to Burp Repeater.
4. Change the `id` parameter to `carlos` and resend the request.
5. Retrieve Carlos's API key and submit it to solve the lab.

Lab: User ID Controlled by Request Parameter with Unpredictable User IDs

1. Find a blog post authored by `carlos`.
2. Click his username and record the GUID from the URL.
3. Log in using `wiener:peter` and navigate to your account page.
4. Send the account request to Burp Repeater and replace the `id` parameter with Carlos's GUID.
5. Retrieve Carlos's API key and submit it to solve the lab.

Lab: User ID Controlled by Request Parameter with Data Leakage in Redirect

1. Log in using `wiener:peter` and navigate to your account page.
2. Send the account request to Burp Repeater.
3. Change the `id` parameter to `carlos` and resend the request.
4. Inspect the response body despite the redirect to the home page, and retrieve Carlos's API key.
5. Submit the API key to solve the lab.

Lab: User ID Controlled by Request Parameter with Password Disclosure

1. Log in using `wiener:peter` and navigate to your account page.
2. Change the `id` parameter in the URL to `administrator`.
3. Inspect the response in Burp Suite and retrieve the administrator's password.
4. Log in using the administrator's credentials and delete the user `carlos`.

Lab: Insecure Direct Object References

1. Open the `Live chat` tab, send a message, and select `View transcript`.
2. Inspect the transcript URL and identify the incrementing filename pattern.
3. Change the filename to `1.txt` and inspect the transcript to find a password belonging to `carlos`.
4. Log in using Carlos's credentials to solve the lab.

Lab: Multi-Step Process with No Access Control on One Step

1. Log in using `administrator:admin` and navigate to the admin panel.
2. Promote `carlos` and send the confirmation request to Burp Repeater.
3. Open a private browser window and log in using `wiener:peter`.
4. Replace the session cookie in Repeater with the non-admin user's session cookie and change the username parameter to `wiener`.
5. Resend the request to promote your own account to administrator.

Lab: Referer-Based Access Control

1. Log in using `administrator:admin` and navigate to the admin panel.
2. Promote `carlos` and send the HTTP request to Burp Repeater.
3. Open a private browser window and log in using `wiener:peter`.
4. Visit `/admin-roles?username=carlos&action=upgrade` and observe that the request is rejected because the `Referer` header is missing.
5. Replace the session cookie in Repeater with the non-admin user's session cookie, change the username parameter to `wiener`, and add a `Referer` header pointing to `/admin`.
6. Resend the request to promote your own account to administrator.